

Mecanismos de seguridad activa

SEGURIDAD Y ALTA DISPONIBILIDAD

Ataques en sistemas personales

Ataques por fuerza bruta

- **Medidas de mitigación:** Utilizar contraseñas largas, únicas y complejas.
- Implementar autenticación multifactor (MFA) para agregar una capa adicional de seguridad.
- Limitar el número de intentos fallidos de inicio de sesión para evitar múltiples intentos consecutivos.
- Utilizar sistemas de detección de intrusos (IDS) para monitorear y bloquear patrones sospechosos.

Ataques en sistemas personales

Phishing

- **Medidas de mitigación:**

- Educar a los usuarios para que no hagan clic en enlaces o descarguen archivos de fuentes no verificadas.
- Implementar filtros de correo electrónico avanzados para detectar y bloquear correos sospechosos.
- Verificar siempre la URL antes de ingresar información sensible.

Ataques en sistemas personales

Ransomware

- **Medidas de mitigación:**

- Mantener copias de seguridad regulares y desconectadas (offline o en la nube).
- Mantener el software y los sistemas operativos actualizados para evitar vulnerabilidades explotadas por el ransomware.
- Utilizar software antimalware y de prevención de intrusiones.
- No pagar el rescate, ya que no garantiza que los datos sean recuperados.

Ataques en sistemas personales

Conti

- **Origen:** Se cree que Conti tiene vínculos con Rusia.
- Conti ha atacado a varias organizaciones gubernamentales y privadas en todo el mundo. Un ataque particularmente notorio ocurrió en **2021** contra los servicios de salud de **Irlanda**, lo que afectó gravemente el sistema de salud del país. Este ataque fue devastador, ya que interrumpió servicios médicos críticos.

REvil (Sodinokibi)

- **Origen:** Este grupo también se cree que tiene sus raíces en Rusia.
- En **2021**, REvil llevó a cabo un ataque masivo contra la empresa proveedora de software **Kaseya**, afectando a miles de empresas en todo el mundo. En el mismo año, fueron responsables del ataque a **JBS**, el mayor productor de carne del mundo, lo que generó interrupciones en la cadena de suministro de alimentos. Estos ataques posicionaron a REvil como una de las bandas más temidas y buscadas.

DarkSide

- **Origen:** Aunque el origen exacto de DarkSide es desconocido, se cree que tiene lazos con Europa del Este o Rusia.
- DarkSide fue responsable del **ataque al oleoducto Colonial Pipeline** en Estados Unidos en **mayo de 2021**, lo que resultó en el cierre temporal de uno de los oleoductos más importantes de la nación, generando interrupciones masivas en el suministro de combustible.

List of Famous Ransomware

WannaCry

- One of the most infamous ransomware attacks in recent years
- Targets vulnerabilities in Microsoft Windows operating systems
- Spread globally in May 2017

Ryuk

- Believed to have originated in Russia
- Targets businesses and organizations
- Uses encryption to lock victims' files in exchange for ransom

SamSam

- Targeted healthcare organizations, causing disruptions and millions of dollars in damages.
- Utilized brute force attacks to gain access to systems.
- Demanded payments ranging from \$6,000 to \$50,000 in Bitcoin.

Petya/NotPetya

- Named after the fictional Russian submarine from "The Hunt for Red October"
- Uses a worm to spread through networks
- Initially believed to be ransomware, later found to be a cyberattack disguised as ransomware

Cryptolocker

- First appeared in 2013
- Targets Windows devices
- Uses encryption to lock victims' files and demands payment in exchange for a decryption key

Locky

- Discovered in February 2016
- Spread through malicious email attachments
- Demands payment in Bitcoin

Maze

- First discovered in May 2019
- Targets businesses and organizations
- Threatens to leak sensitive data if the ransom is not paid

GandCrab

- Active from January 2018 to May 2019
- Discontinued by its creators after allegedly earning over \$2 billion in ransom payments
- Spread through exploit kits and phishing emails

Sodinokibi/REvil

- Discovered in April 2019
- Believed to be linked to the Russian hacking group "GOLD SOUTHFIELD"
- Targets large corporations and demands large ransom payments

Bad Rabbit

- Hit Eastern Europe in 2017, spread through fake Adobe Flash installers on compromised websites.
- Encrypted files and demanded payment in Bitcoin.
- Used similar code to Petya ransomware.

Ataques en sistemas personales

Spyware

- **Medidas de mitigación:**

- Usar software antimalware actualizado que detecte y elimine spyware.
- Revisar permisos de las aplicaciones instaladas y evitar instalar software de fuentes no confiables.
- Mantener los navegadores actualizados y usar extensiones que bloqueen rastreadores y anuncios maliciosos.

Ataques en sistemas personales

Ataques de día cero (Zero-Day)

- **Medidas de mitigación:**

- Mantener actualizados los sistemas operativos y aplicaciones para recibir parches tan pronto como estén disponibles.
- Monitorear constantemente las actualizaciones de seguridad y los informes de vulnerabilidades.
- Implementar sistemas de detección de intrusos (IDS) que puedan detectar comportamientos anómalos.

Stuxnet (2010)

- **Descripción:** Stuxnet es uno de los ataques de día cero más famosos y sofisticados de la historia. Se trató de un **gusano informático** que explotó varias vulnerabilidades de día cero en **Windows** para atacar los sistemas de control industrial (SCADA), específicamente los utilizados en las centrifugadoras nucleares en Irán.

Heartbleed (2014)

- **Descripción:** Heartbleed no es un ataque en sí, sino una vulnerabilidad de día cero descubierta en la **biblioteca OpenSSL**, utilizada para cifrar la comunicación en internet. La vulnerabilidad permitía que un atacante pudiera robar datos directamente de la memoria de los servidores, lo que incluía claves de cifrado, credenciales de usuario y otros datos sensibles.

EternalBlue (2017)

- **Descripción:** EternalBlue es una vulnerabilidad de día cero en el protocolo **SMB (Server Message Block)** de Microsoft Windows. Fue descubierta y explotada por la Agencia de Seguridad Nacional (NSA) de los Estados Unidos, pero el exploit fue robado y filtrado por un grupo de hackers conocido como **Shadow Brokers**. Poco después, la vulnerabilidad fue utilizada en dos de los ataques de ransomware más destructivos: **WannaCry** y **NotPetya**.

Ataques en sistemas personales

Ataques DDoS (Denegación de Servicio Distribuida)

- **Medidas de mitigación:**

- Usar soluciones de mitigación DDoS, como firewalls o sistemas de protección en la nube, para filtrar tráfico malicioso.
- Configurar redundancia en servidores y redes para distribuir la carga de tráfico.
- Implementar un sistema de monitoreo que permita identificar el ataque en las fases iniciales.

Aurora (2009-2010)

- **Descripción:** El ataque conocido como "**Operation Aurora**" fue una serie de ciberataques dirigidos a varias empresas tecnológicas, financieras y de defensa, con **Google** siendo uno de los blancos más importantes. Se explotó una vulnerabilidad de día cero en **Internet Explorer**, que permitió a los atacantes infiltrarse en los sistemas de las empresas y robar propiedad intelectual y datos confidenciales.

Log4Shell (2021)

- **Descripción:** Log4Shell fue una vulnerabilidad de día cero en **Apache Log4j**, una biblioteca de registro muy utilizada en aplicaciones Java para registrar datos de actividad. Esta vulnerabilidad permitía a los atacantes ejecutar código remoto en los servidores afectados sin necesidad de autenticación, simplemente enviando una solicitud maliciosa con datos manipulados.

CVE-2020-0601 (Crypt32.dll Vulnerability, 2020)

- **Descripción:** Esta vulnerabilidad de día cero fue descubierta en la biblioteca **Crypt32.dll** de Microsoft Windows, que maneja la validación de certificados criptográficos y mensajes cifrados. El fallo permitía a los atacantes explotar la validación incorrecta de los certificados, lo que les daba la capacidad de **falsificar firmas digitales** y ejecutar código malicioso en sistemas afectados.

Clasificación de los ataques y amenazas

Ataques de software

Malware:

- Incluye **virus**, **gusanos**, **troyanos**, **ransomware** y **spyware**. Estos programas maliciosos pueden dañar sistemas, robar información o secuestrar recursos de la víctima.
- **Contramedidas:** Uso de **software antimalware**, mantener los sistemas actualizados con los últimos parches de seguridad, educación al usuario sobre la descarga de archivos sospechosos y la implementación de **firewalls**.

Clasificación de los ataques y amenazas

Ataques de software

Ataques de día cero:

- Aprovechan vulnerabilidades en el software que son desconocidas para los desarrolladores y que no han sido parcheadas.
- **Contramedidas:** Uso de **Sistemas de Prevención de Intrusiones (IPS)**, monitorización constante de las vulnerabilidades y actualizaciones rápidas una vez que los parches están disponibles. Mantener buenas prácticas de **seguridad en capas** también puede ayudar a mitigar los daños de un ataque de día cero.

Clasificación de los ataques y amenazas

Ataques de software

Ataques de día cero - Ataque a Google Chrome (2012)

- En 2012, durante la conferencia de seguridad Pwn2Own, el investigador **Sergey Glazunov** encontró y explotó una vulnerabilidad de día cero en el navegador **Google Chrome**. Aprovechando una falla en el manejo de memoria, Glazunov pudo comprometer el navegador y obtener el control del sistema.

Clasificación de los ataques y amenazas

Ataques de software

Inyección de código:

- Incluye técnicas como la **inyección SQL** y el **Cross-Site Scripting (XSS)**, que permiten a los atacantes inyectar código malicioso en aplicaciones vulnerables, accediendo a bases de datos o tomando el control de sitios web.
- **Contramedidas:** Validación de entradas, usar consultas preparadas y escapar adecuadamente los datos del usuario antes de incluirlos en el código. Las auditorías de seguridad y pruebas periódicas pueden identificar vulnerabilidades antes de que los atacantes las exploten.

Clasificación de los ataques y amenazas

Ataques de software

- **Heartland Payment Systems (2008)**
- En 2008, **Heartland Payment Systems**, una de las mayores empresas de procesamiento de pagos de Estados Unidos, fue víctima de un ataque de **inyección SQL**. Los atacantes explotaron vulnerabilidades en el sistema web de la empresa, lo que les permitió inyectar código malicioso y acceder a los datos de las transacciones financieras.
- El ataque comprometió más de **130 millones de tarjetas de crédito y débito**, convirtiéndolo en uno de los mayores robos de datos en la historia de los Estados Unidos.

Clasificación de los ataques y amenazas

Ataques de red

Denegación de Servicio (DoS) y Denegación de Servicio Distribuido (DDoS):

- Estos ataques buscan inundar un servidor o red con tráfico excesivo para que se vuelva inaccesible para los usuarios legítimos.
- **Contramedidas:** Uso de **firewalls**, servicios de mitigación de DDoS en la nube, y redes de entrega de contenido (CDN). También es útil tener una infraestructura redundante y monitoreo constante para identificar ataques rápidamente.

Clasificación de los ataques y amenazas

Ataques de red

Ataques DDoS - Ataque a Dyn (2016)

- En octubre de 2016, la empresa Dyn, que proporcionaba servicios de DNS, fue objeto de un masivo ataque DDoS. Los atacantes utilizaron la botnet Mirai, compuesta por millones de dispositivos IoT (como cámaras y routers), para inundar los servidores de Dyn con tráfico hasta el punto de colapsarlos.
- Este ataque causó interrupciones generalizadas en sitios web y servicios como Twitter, Netflix, Reddit, y Spotify.

Clasificación de los ataques y amenazas

Ataques de software

Ataques Man in the Middle (MitM):

- El atacante intercepta la comunicación entre dos partes para espiar o alterar la información transmitida.
- **Contramedidas:** Uso de **cifrado de extremo a extremo** (por ejemplo, HTTPS), implementar autenticación robusta y asegurar que las redes inalámbricas estén adecuadamente protegidas (WPA3). Además, verificar los certificados digitales es esencial para prevenir el spoofing de sitios web.

Clasificación de los ataques y amenazas

Ataques de software



Ataque Man in the Middle (MitM) - Hackeo del Wi-Fi de Starbucks (2017)

- En 2017, se descubrió que los atacantes habían llevado a cabo ataques **Man in the Middle (MitM)** en varias ubicaciones de **Starbucks** al manipular las redes Wi-Fi públicas de la empresa. Los atacantes interceptaron el tráfico no cifrado de los usuarios conectados a la red, lo que les permitió robar información personal, como credenciales de acceso y datos bancarios.

Clasificación de los ataques y amenazas

Ataques de software

Ataques de suplantación (Spoofing):

- El atacante se hace pasar por un usuario, dispositivo o red para obtener acceso no autorizado.
- **Contramedidas:** Implementar **autenticación multifactor (MFA)**, utilizar **filtros de IP** y monitoreo de direcciones **MAC** para evitar la suplantación. También es recomendable configurar DNS con medidas de autenticación, como **DNSSEC**, para evitar ataques de spoofing a nivel de red.

Clasificación de los ataques y amenazas

Ataques de software

- Ataques de suplantación (Spoofing) - Ataque de suplantación de DNS a MyEtherWallet (2018)
- En abril de 2018, los atacantes lanzaron un ataque de **spoofing de DNS** contra **MyEtherWallet**, una popular cartera de criptomonedas. Los atacantes redirigieron a los usuarios hacia una versión falsa del sitio web, robando sus claves privadas y accediendo a sus fondos de Ethereum.
- Durante el ataque, se robaron más de **\$150,000** en criptomonedas de los usuarios.

Clasificación de los ataques y amenazas

Ataques basados en ingeniería social

Phishing:

- Los atacantes envían correos electrónicos o crean sitios web que parecen legítimos para engañar a las víctimas y obtener sus credenciales o información personal.
- **Contramedidas:** Capacitación constante a los usuarios para identificar correos sospechosos, implementar filtros de correos electrónicos avanzados y utilizar autenticación multifactor para proteger cuentas en caso de robo de contraseñas.

Clasificación de los ataques y amenazas

Ataques basados en ingeniería social

Phishing - Ataque de phishing a la campaña de Hillary Clinton (2016)

- En 2016, la campaña presidencial de **Hillary Clinton** fue blanco de un ataque de **phishing** que comprometió las cuentas de correo electrónico de varios altos funcionarios del **Comité Nacional Demócrata (DNC)**. Los atacantes enviaron correos electrónicos falsos que parecían legítimos, engañando a los destinatarios para que proporcionaran sus credenciales de acceso.
- Las cuentas de correo electrónico comprometidas fueron utilizadas para acceder a documentos internos sensibles, que luego fueron filtrados al público a través de **WikiLeaks**

Clasificación de los ataques y amenazas

Ataques basados en ingeniería social

Pretexto:

- El atacante crea una narrativa convincente para engañar a la víctima y obtener acceso a información confidencial.
- **Contramedidas:** Capacitación en seguridad para ayudar a las personas a identificar situaciones de pretexto y protocolos claros para la verificación de identidad antes de compartir información sensible.

Clasificación de los ataques y amenazas

Ataques basados en ingeniería social

- **Pretexto - Ataque de pretexto a Target (2013)**
- En 2013, los hackers atacaron a la cadena minorista Target utilizando una táctica de **pretexto**. Los atacantes se hicieron pasar por **empleados de una empresa subcontratada de aire acondicionado** y engañaron al equipo de Target para obtener acceso a su red interna. A través de este acceso, instalaron malware en los puntos de venta (POS) de las tiendas Target.
- Los atacantes robaron los datos de **40 millones de tarjetas de crédito y débito** de los clientes de Target.

Clasificación de los ataques y amenazas

Ataques físicos

Shoulder Surfing:

- El atacante observa directamente a la víctima para obtener información confidencial, como contraseñas o PIN.
- **Contramedidas:** Usar pantallas de privacidad, ser consciente del entorno y cubrir el teclado cuando se ingresa información confidencial.

Clasificación de los ataques y amenazas

Ataques físicos

Shoulder Surfing - Robo de PIN en cajeros automáticos

- Un ataque común de **shoulder surfing** ocurre en los cajeros automáticos, donde los delincuentes observan a los usuarios mientras introducen su **PIN** o utilizan cámaras ocultas para capturar esta información.

Clasificación de los ataques y amenazas

Ataques físicos

Tailgating:

- El atacante sigue a alguien que tiene acceso a un área restringida para entrar sin autorización.
- **Contramedidas:** Implementar sistemas de **acceso con tarjetas de identificación** y puertas con bloqueo automático. También es útil promover una cultura de "cero confianza", donde los empleados no permitan el acceso a personas desconocidas.

Clasificación de los ataques y amenazas

Ataques físicos

Tailgating - Acceso no autorizado en oficinas de Google

- En un caso reportado, un intruso siguió a un empleado real de Google que usó su tarjeta de acceso para entrar en una oficina. El atacante, sin su propia tarjeta de identificación, aprovechó la cortesía de los empleados que no preguntaron quién era.
- Aunque en este caso no se reportaron daños significativos, el ataque demostró lo fácil que es aprovechar la confianza humana para obtener acceso a áreas restringidas.

Anatomía de ataques y análisis de software malicioso

Infiltración

- En esta etapa, el malware logra entrar en el sistema de la víctima. Las formas más comunes de infiltración incluyen **archivos adjuntos maliciosos** en correos electrónicos de phishing, descargas de **sitios web infectados**, **dispositivos USB** contaminados o a través de vulnerabilidades no parchadas en el software o sistema operativo.

Anatomía de ataques y análisis de software malicioso

Instalación

- Una vez que el malware ha ingresado al sistema, procede a **instalarse**. Puede hacerlo copiándose en múltiples ubicaciones del sistema, modificando el **registro de Windows** para ejecutarse al iniciar el ordenador o incluso descargando **módulos adicionales** para aumentar su funcionalidad.

Anatomía de ataques y análisis de software malicioso

Ejecución

- En esta fase, el malware se activa y ejecuta su **carga útil**, que puede variar dependiendo del tipo de malware. Las cargas útiles comunes incluyen el **robo de datos** personales, el **cifrado de archivos** (ransomware), el uso de los recursos del sistema para **minar criptomonedas**, o el uso del sistema infectado como base para lanzar ataques contra otros sistemas (por ejemplo, ataques DDoS).

Anatomía de ataques y análisis de software malicioso

Propagación

- Muchos tipos de malware intentan propagarse a otros sistemas dentro de la red o incluso a otras redes. Los métodos de propagación incluyen **explotar vulnerabilidades** en la red, enviar copias a través de **correos electrónicos** o infectar **dispositivos USB** que, al conectarse a otro sistema, también lo infectan.

Anatomía de ataques y análisis de software malicioso

- **Exfiltración**
- En esta última fase, el malware transmite la información robada de vuelta al atacante. Esto puede incluir datos personales, como **contraseñas, información bancaria**, o incluso secretos corporativos. Los datos suelen enviarse a servidores controlados por los ciberdelincuentes.

Tipos de Malware y su Anatomía

Virus:

- Los virus se adhieren a archivos o programas legítimos, y cuando el archivo infectado es ejecutado por el usuario, el virus también se activa. Una vez activo, puede replicarse e infectar otros archivos y programas.
- **Ejemplo:** ILOVEYOU fue un virus que se propagaba a través de correos electrónicos con un archivo adjunto llamado "LOVE-LETTER-FOR-YOU.txt.vbs". Al abrir el archivo, el virus se ejecutaba y se replicaba enviando copias a todos los contactos de la víctima.

Tipos de Malware y su Anatomía

Gusanos:

- A diferencia de los virus, los gusanos no necesitan que un archivo sea ejecutado por el usuario. Los gusanos se propagan automáticamente explotando vulnerabilidades en la red o el sistema.
- **Ejemplo: Blaster Worm** explotó una vulnerabilidad en Windows y se propagó rápidamente a través de redes, reiniciando repetidamente los ordenadores infectados.

Tipos de Malware y su Anatomía

Keyloggers:

- Un keylogger es un tipo de spyware especializado que **registra todas las pulsaciones de teclado** del usuario. Los keyloggers suelen usarse para robar contraseñas y otra información sensible.
- **Ejemplo: Olympic Vision**, un keylogger, fue responsable del robo de miles de credenciales bancarias mediante la monitorización silenciosa de las pulsaciones de teclado de los usuarios infectados.

Tipos de Malware y su Anatomía

Spyware:

- El spyware se instala en el sistema sin que el usuario lo sepa y opera en segundo plano para **recopilar información** sobre las actividades del usuario. Puede capturar todo, desde hábitos de navegación hasta credenciales de acceso.
- **Ejemplo: CoolWebSearch** es un spyware que toma el control del navegador web del usuario, redirigiendo las búsquedas a sitios de publicidad y rastreando las actividades en línea sin el consentimiento del usuario.

Contramedidas en sistemas personales

Control de acceso al sistema

- **Contraseñas fuertes y únicas:** Usa contraseñas que combinen mayúsculas, minúsculas, números y símbolos. Evita contraseñas comunes o fáciles de adivinar. Un buen hábito es utilizar un **gestor de contraseñas** para almacenar contraseñas complejas.
- **Autenticación de dos factores (2FA):** Implementar 2FA añade una capa adicional de seguridad. Incluso si un atacante obtiene tu contraseña, necesitará el segundo factor (generalmente un código enviado al teléfono o una aplicación de autenticación).
- **Limitar los privilegios de usuario:** No uses cuentas con privilegios de administrador para tareas cotidianas. Usa una cuenta de usuario estándar y reserva la cuenta de administrador para tareas específicas.
- **Biometría:** Si tu dispositivo lo permite, utiliza huellas dactilares, reconocimiento facial o iris como un método seguro de autenticación.

Contramedidas en sistemas personales

Actualización de sistemas y aplicaciones

- **Actualizaciones automáticas:** Configura las actualizaciones automáticas en tu sistema operativo y aplicaciones para garantizar que siempre tengas los últimos parches de seguridad.
- **Vigilancia de actualizaciones críticas:** Asegúrate de aplicar manualmente parches críticos, especialmente para aplicaciones como navegadores, programas de productividad y software de seguridad.

Contramedidas en sistemas personales

Actualización de sistemas y aplicaciones

- **Actualizaciones automáticas:** Configura las actualizaciones automáticas en tu sistema operativo y aplicaciones para garantizar que siempre tengas los últimos parches de seguridad.
- **Vigilancia de actualizaciones críticas:** Asegúrate de aplicar manualmente parches críticos, especialmente para aplicaciones como navegadores, programas de productividad y software de seguridad.

Contramedidas en sistemas personales

- **Firewall y antivirus**

- **Firewall:** Usa el firewall integrado de tu sistema operativo y configura reglas personalizadas para bloquear el tráfico sospechoso o no autorizado.
- **Antivirus:** Mantén un antivirus actualizado que pueda detectar y eliminar virus, troyanos, ransomware, spyware y otros tipos de malware. Además, algunas soluciones de antivirus también ofrecen protección contra sitios web maliciosos y correos de phishing.
- **Firewall de red adicional:** Si estás en una red doméstica, un router con firewall integrado puede agregar otra capa de seguridad para todo tu tráfico de red.

Contramedidas en sistemas personales

- **Copia de seguridad de datos**

- **Copias de seguridad periódicas:** Haz copias de seguridad regulares, al menos semanalmente. Usa servicios en la nube o unidades externas.
- **Almacenamiento separado:** Las copias de seguridad deben guardarse en un lugar separado y seguro. Almacenar una copia de seguridad **offline** o en la nube protege tus datos incluso si tu sistema principal es comprometido.
- **Versionado:** Usa herramientas que ofrezcan versionado para que puedas restaurar versiones anteriores de los archivos, en caso de que una copia esté comprometida por malware.

Contramedidas en sistemas personales

- **Navegación segura**

- **HTTPS:** Asegúrate de que los sitios web que visitas utilicen **HTTPS** para proteger la transmisión de datos.
- **Bloqueadores de scripts o anuncios:** Usa extensiones en el navegador como **uBlock Origin** o **NoScript** para bloquear anuncios o scripts maliciosos que podrían contener malware.
- **Descargas seguras:** Descarga programas solo de fuentes oficiales o de confianza. Evita descargar archivos adjuntos o hacer clic en enlaces sospechosos de correos electrónicos no solicitados.
- **Antiphishing:** Algunos navegadores y antivirus incluyen protección contra sitios de phishing que intentan robar información personal o credenciales de acceso.

Contramedidas en sistemas personales

- **Educación y concienciación**

- **Cursos de ciberseguridad:** Participa en cursos en línea gratuitos o seminarios sobre ciberseguridad que cubran temas como phishing, malware, y cómo proteger tus cuentas en línea.
- **Reconocer amenazas:** Aprende a identificar correos electrónicos de phishing, enlaces maliciosos y comportamientos sospechosos en tu ordenador. Una señal común es el uso de **URL acortadas** o que parecen similares a sitios web legítimos.
- **Cultura de seguridad:** Adopta buenos hábitos como bloquear el ordenador cuando no esté en uso, cerrar sesiones después de usar servicios en línea, y compartir información solo con personas y servicios de confianza.

Control de acceso al sistema

Control de acceso discrecional (DAC)

- El control de acceso discrecional permite que los propietarios de los recursos determinen quién tiene acceso y qué acciones pueden realizar sobre esos recursos. Es el tipo más flexible de control de acceso.
- **Ventajas:** Flexibilidad para los propietarios en cuanto a la gestión de sus propios datos.
- **Desventajas:** Puede ser menos seguro en entornos más grandes, ya que la gestión de permisos por parte de múltiples usuarios puede volverse confusa y propensa a errores.

Control de acceso al sistema

Control de acceso obligatorio (MAC)

- Este tipo de control de acceso es más estricto y se basa en políticas de seguridad predefinidas. Tanto los usuarios como los recursos tienen asignados niveles de seguridad, y las reglas de acceso se determinan en función de estos niveles. Aquí, los usuarios no pueden modificar los permisos de los archivos, ya que son gestionados centralmente.
- **Ventajas:** Alta seguridad, ideal para proteger información sensible. El control no está en manos de los usuarios, lo que reduce el riesgo de errores humanos.
- **Desventajas:** Es menos flexible y más complejo de implementar y gestionar, especialmente en organizaciones más dinámicas.

Control de acceso al sistema

- **Control de acceso basado en roles (RBAC)**
- En el control de acceso basado en roles, los permisos se asignan en función de los roles que desempeñan los usuarios dentro de una organización. Cada rol tiene un conjunto predeterminado de permisos, y los usuarios obtienen permisos en función de los roles asignados. Esto simplifica mucho la gestión de permisos en entornos grandes.
- **Ventajas:** Escalabilidad y facilidad de gestión, especialmente en organizaciones grandes. Facilita la asignación y modificación de permisos a medida que los empleados cambian de rol dentro de la organización.
- **Desventajas:** Si los roles no están definidos de manera adecuada o precisa, podría llevar a problemas de sobrepermisos o subpermisos, lo que podría representar un riesgo de seguridad.

Aplicación del control de acceso en entornos personales y empresariales

Entornos personales:

- En un sistema personal, el control de acceso puede ser tan sencillo como establecer una contraseña segura y asignar permisos a carpetas o archivos específicos. Por ejemplo, si compartes tu ordenador con otras personas, puedes restringir el acceso a tus archivos personales, permitiendo solo la lectura o escritura a ciertos usuarios. Aquí se suele utilizar DAC.

Aplicación del control de acceso en entornos personales y empresariales

Entornos empresariales:

- En un entorno corporativo, el control de acceso es mucho más complejo. Se aplican sistemas como la **gestión de identidades y accesos (IAM)**, que permiten centralizar la autenticación y el control de permisos. Además, es común la utilización de tecnologías como:
 - **Autenticación de dos factores (2FA)**: Requiere que el usuario ingrese una segunda forma de autenticación, como un código enviado a su teléfono, para acceder a los sistemas.
 - **Identidad como servicio (IDaaS)**: Soluciones basadas en la nube que permiten la gestión de identidades y accesos para las aplicaciones en línea de la empresa.
 - **Políticas de contraseñas fuertes** y la gestión de permisos según roles (RBAC) son ampliamente utilizadas para simplificar la administración y mejorar la seguridad en empresas.

Actualización de sistemas y aplicaciones

Beneficios de las actualizaciones de sistemas y aplicaciones

- Corrección de vulnerabilidades de seguridad
- Mejora del rendimiento
- Nuevas características y funcionalidades

Riesgos de no actualizar el software

- Exposición a vulnerabilidades
- Malware y ransomware
- Incompatibilidades

Actualización de sistemas y aplicaciones

Mejores prácticas para mantener los sistemas y aplicaciones actualizados

- Actualizaciones automáticas
- Revisión manual periódica
- Uso de herramientas de gestión de actualizaciones (en entornos empresariales)
- Priorización de actualizaciones críticas
- Control de versiones y compatibilidad

Actualización de sistemas y aplicaciones

Actualización de firmware

- No solo el software debe mantenerse actualizado. El **firmware** de los dispositivos, que controla el hardware, también recibe actualizaciones importantes que mejoran la seguridad y el rendimiento.

Autenticidad de aplicaciones y actualizaciones

Firmas digitales

- Las firmas digitales son como un "sello de aprobación" que garantiza que una aplicación o actualización proviene del desarrollador original y no ha sido alterada desde su creación. Utilizan criptografía asimétrica, donde el desarrollador firma la aplicación con su **clave privada** y cualquier usuario puede verificar la firma con la **clave pública** correspondiente.

Autenticidad de aplicaciones y actualizaciones

Certificados de seguridad

- Los certificados de seguridad son emitidos por **Autoridades de Certificación (CA)** confiables, que validan la identidad de los desarrolladores y emiten un certificado digital. Este certificado puede utilizarse para firmar aplicaciones o actualizaciones, verificando que la fuente es auténtica.

Autenticidad de aplicaciones y actualizaciones

Hashes de verificación

- Un **hash** es una cadena de texto generada a partir de un archivo mediante un algoritmo criptográfico (por ejemplo, SHA-256 o MD5). Los desarrolladores suelen proporcionar el hash de un archivo para que los usuarios puedan verificar que el archivo descargado es exactamente igual al original. Al comparar el hash del archivo descargado con el proporcionado por el desarrollador, los usuarios pueden asegurarse de que el archivo no ha sido alterado.

Autenticidad de aplicaciones y actualizaciones

Tiendas de aplicaciones oficiales

- Las tiendas de aplicaciones oficiales, como **Google Play Store** (Android), **App Store** (iOS) y **Microsoft Store**, son plataformas que revisan y controlan las aplicaciones que se publican en sus ecosistemas. Estas tiendas tienen políticas estrictas para garantizar que las aplicaciones sean seguras y auténticas antes de permitir su distribución.

Herramientas avanzadas para la seguridad activa



OWASP

(Open Web Application Security Project) es una organización global sin fines de lucro dedicada a mejorar la seguridad del software. Fundada en 2001, OWASP proporciona recursos, herramientas y conocimientos que ayudan a organizaciones y desarrolladores a crear aplicaciones web seguras. Su objetivo principal es aumentar la conciencia sobre la seguridad en el desarrollo de software, y sus proyectos son ampliamente reconocidos en el campo de la seguridad de aplicaciones web.

Principales objetivos de OWASP

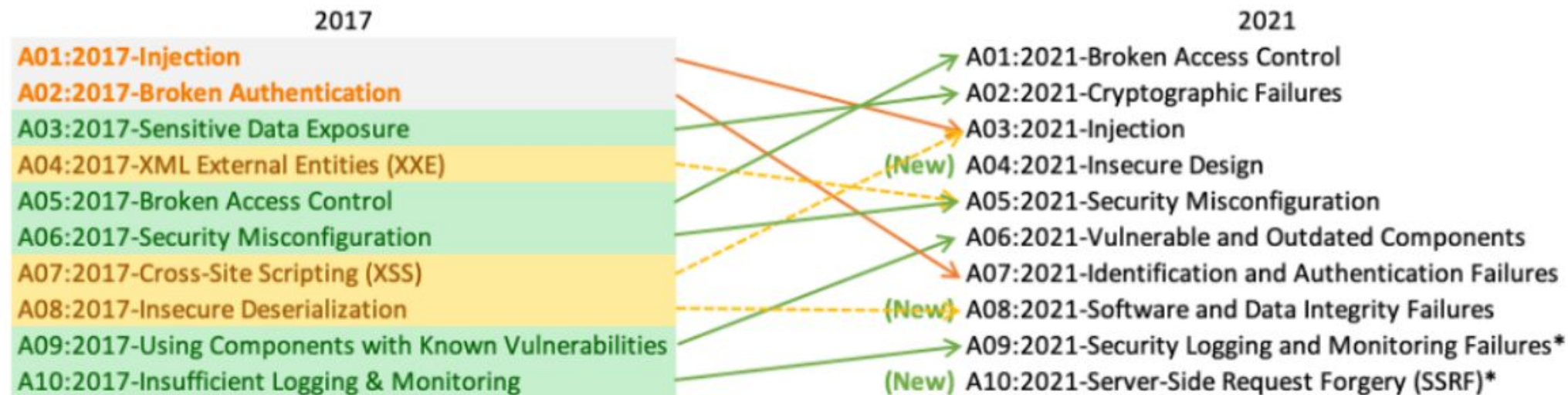
- **Promover la seguridad del software:** OWASP se centra en educar a desarrolladores, gerentes y organizaciones sobre las mejores prácticas para crear aplicaciones seguras.
- **Proporcionar herramientas y recursos:** La organización desarrolla una variedad de herramientas y recursos gratuitos, como guías, listas de vulnerabilidades, y herramientas de análisis de seguridad.
- **Facilitar la colaboración global:** Al ser una comunidad abierta, OWASP fomenta la colaboración entre expertos en ciberseguridad de todo el mundo.

Proyectos más importantes de OWASP

- OWASP Top 10

Top 10 Web Application Security Risks

There are three new categories, four categories with naming and scoping changes, and some consolidation in the Top 10 for 2021.



* From the Survey

Documental Hackers

